第 15 章練習解答　安全

> 題號與本章練習題 PDF 一一對應。答案保留成立條件、關鍵推導與必要的反例。

OS15-E01　越界與防禦邊界

1. 需13 bytes，超容量1。reject契約先驗n≤11，否則拒絕；truncate契約copy min(n,11)=11並buf[11]=0，再明確回報截斷。只copy11但不補NUL不能推出合法字串。
2. 不能，NX檢查執行權而非一般寫入邊界。若越界改到相鄰授權資料，沒有執行stack code仍可出錯；須修copy界限。

檢查。 data長與buffer容量、終止字元分開。

OS15-E02　DoS 的 pending slots

1. L=λW，所以λ=2000/8=250 requests/s。這是穩態占用模型；突發與上限拒絕可使實際行為不同，不能宣稱低於250就任何時刻都不滿。
2. 多個合法user經同NAT共用IP，可能共同分一個quota；對手也可能有多來源。policy需說明key與公平性，不能由有rate limit推定合法使用不受影響。

檢查。 單位是requests/s，不是bytes/s。

OS15-E03　重用 keystream

1. c1=0xB5，c2=0xD5；c1 XOR c2=0x60=m1 XOR m2。s=c1 XOR m1=0xA5；m2=c2 XOR s=0x70。
2. 否，是XOR的結合律與s XOR s=0。錯誤在同keystream重用；底層generator再強也不消除此代數洩漏。

檢查。 此玩具式只演示nonce/keystream重用，非生產加密。

OS15-E04　RSA 的非互質明文

1. $c=5^3 \bmod 55=15$。$15^2 \bmod 55=5$；$15^4=25$；$15^8=20$；$15^{16}=15$。$27=16+8+2+1$，依序 $15\times20 \bmod 55=25$，$\times5 \bmod 55=15$，$\times15 \bmod 55=5$，解回m。
2. 模p是0所以冪後仍0；模q用Fermat因5與11互質，ed=1+2×4×10使5^ed≡5 mod11。兩模同餘再用CRT得mod55同餘。不能直接對mod55套需要互質的Euler。

檢查。 正確性證明不證此小RSA具有安全性。

Lin Cing https://github.com/xinhi6716/computer-science-self-study

第 15 章練習解答　安全 （續）

OS15-E05　MAC、hash 與 replay

1. 對手可換m′並自己重算H(m′)。MAC不知key難偽造新內容，但可完整複製曾有效的(m,tag)；需驗session/nonce/seq的狀態新鮮性。
2. 驗tag後，在同lock/transaction中驗nonce仍pending並改used；只有一個thread能成功。若check與consume分離，兩者都可能讀pending後接受。若帶業務效果，去重狀態與效果也須原子/可恢復地連結。

檢查。 nonce消耗與外部副作用exactly-once不是同一結論。

OS15-E06　歷史 TLS 的身分與forward secrecy

1. 不足。需驗目標名稱/用途/信任鏈等，且由後續完成RSA key exchange與正確Finished確認對端可導出master並驗handshake transcript。單純轉送別人的certificate不需持其private key。
2. 否。錄到的RSA-encrypted premaster可在static private key外洩後解密，再依公開randoms導master/traffic keys。此歷史RSA模式不具forward secrecy；刪session keys本身不能補上。

檢查。 限定RSA key exchange，不把答案套到所有TLS版本或套件。

OS15-E07　Salt 與猜測成本

1. 500×20000=10000000次；×0.002=20000 s≈5.556 h。salt可與verifier同存並公開，目的是跨record隔開計算，不是保密key。
2. 不會。verifier已外洩時不經online檢查；2 ms仍是本題KDF成本。實際平行硬體/記憶體限制另定，本串行模型不宣稱實測攻擊時間。

檢查。 不同salt不使字典失效，只使預算表不易跨記錄共用。

OS15-E08　IDS 的 base rate

1. attack100、normal99900；TP90、FN10、FP999、TN98901；precision=90/(90+999)=90/1089≈8.264%。不是TPR90%。
2. 由πTPR≥(1−π)FPR，得FPR≤0.001×0.9/0.999≈0.000900901，約0.09009%。必須明列normal事件為分母。

檢查。 alarm正確率與真正率使用不同分母。

第 15 章練習解答　安全 （續）

OS15-E09　Firewall 真正允許什麼

1. 依序deny、allow、deny、若符合既存state則allow。目的port相同不夠，source/destination zone、direction與state都要符合。
2. 仍能利用明列允許的DB5432通道；segmentation限制其他入口，不取消必要信任。DB須驗帳密/角色/查詢scope，且監控該合法通道的濫用。

檢查。 返回封包須符合state，不是任意聲稱established即可。

OS15-E10　Windows7 ordered DACL 與 MIC

1. request r：deny與remaining r不相交，allow移除r，DACL允許；MIC只有NWU不擋read，故本模型允許。request rw：MIC先以write-up拒，若單獨追DACL也會在deny G,w拒，不能據allow U,rw覆蓋。
2. 非canonical順序下allow先滿足全部remaining而DACL可成功，後面的deny不再掃；但MIC的write-up仍拒。因此不應說所有deny不管位置必覆蓋allow，也不應說DACL成功就必通過MIC。
3. 本普通DACL模型NULL無DACL則給存取；empty存在但無ACE，remaining無法清空而拒。最終還需mandatory policy等檢查。

檢查。 把每層判斷分開，不混成一條口訣。

Lin Cing
https://github.com/xinhi6716/computer-science-self-study

第 15 章練習解答　安全 （續）

原創驗算程式附錄: security_models.py

```
"""Original finite arithmetic/state examples, not cryptographic deployment code."""
from fractions import Fraction
import hmac,hashlib
def precision(pi,tpr,fpr):return pi*tpr/(pi*tpr+(1-pi)*fpr)
def dacl(request,groups,entries):
 remaining=set(request)
 for kind,sid,mask in entries:
  if sid not in groups:continue
  if kind=='deny' and remaining&mask:return False
  if kind=='allow':remaining-=mask
  if not remaining:return True
 return False
if __name__=='__main__':
 assert pow(12,3,55)==23 and pow(23,27,55)==12
 assert [pow(15,2**i,55) for i in range(5)]==[15,5,25,20,15]
 assert all(pow(pow(m,3,55),27,55)==m for m in range(55))
 assert 0xE7^0xE4==0x41^0x42
 pr=precision(Fraction(1,10000),Fraction(9,10),Fraction(1,1000))
 assert pr==Fraction(100,1211)
 assert not dacl({'r','w'},{'U','G'},[('deny','G',{'w'}),('allow','U',{'r','w'})])
 assert dacl({'r','w'},{'U','G'},[('allow','U',{'r','w'}),('deny','G',{'w'})])
 key=b'local teaching
key';nonce=42;message=b'login|U|42|server';tag=hmac.digest(key,message,'sha256');pending=
{nonce}
 def accept():
  if hmac.compare_digest(tag,hmac.digest(key,message,'sha256')) and nonce in pending:
   pending.remove(nonce);return True
  return False
 assert accept() and not accept()
 print('RSA m12:',23,'->',12,'; all 55 toy messages checked (proof remains CRT)')
 print('IDS precision:',float(pr),'DACL order counterexample and sequential nonce replay
passed')
```

Lin Cing https://github.com/xinhi6716/computer-science-self-study

參考資料與署名

Abraham Silberschatz, Peter B. Galvin, Greg Gagne. Operating System Concepts, 9th Edition.

Lin Cing 原創教學整理。原創內容以 CC BY 4.0 授權；參考書籍不隨教材散布。
https://github.com/xinhi6716/computer-science-self-study